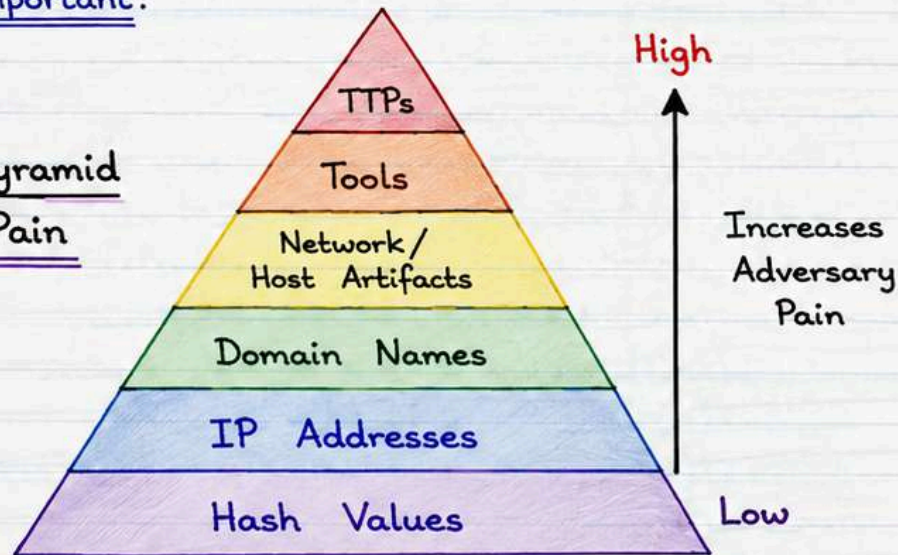


Task 1

Introduction

- ★ This well-renowned concept is being applied to cybersecurity solutions like Cisco Security, or SentinelOne, and SOCRadar, to improve the effectiveness of CTI (Cyber Threat Intelligence), threat hunting, and incident response exercises.
- ★ Understanding the Pyramid of Pain concept as a Threat Hunter, Incident Responder, or SOC Analyst is important.

The Pyramid of Pain



Who Should Know This?



Threat Hunters



Incident Responders



SOC Analysts



Anyone in Cybersecurity!

The Pyramid of Pain is a concept that shows which indicators are more painful (harder) for attackers to change.

Key Idea:

- The higher you go in the pyramid, the more **painful** (costly and difficult) it is for attackers to change their behaviour.

Why it Matters?

- Helps **prioritize** intelligence that delivers the most impact.
- Improves **CTI**, threat hunting, and incident response.
- Focus on what lasts longer and is **harder** for attackers to replace.

Are you ready to explore what hides inside the Pyramid of Pain? ?

Task 2

Hash Values (Trivial)

As per Microsoft, the **hash value** is a numeric value of a fixed length that uniquely identifies data. A hash value is the result of a hashing algorithm.

Common Hashing Algorithms:

- ① **MD5** (Message Digest, defined by RFC 1321)
 - Designed by Ron Rivest in 1992.
 - Produces a 128-bit hash value (32 hex digits).
 - **NOT** considered cryptographically secure.
 - In 2011, IETF published RFC 6151 which highlighted attacks including **hash collision**.
- ② **SHA-1** (Secure Hash Algorithm 1, defined by RFC 3174)
 - Invented by NSA in 1995.
 - Produces a 120-bit hash value (40 hex digits).
 - NIST **deprecated** SHA-1 in 2011.
 - Banned for digital signatures at end of 2013 due to **brute-force attacks**.
 - NIST recommends using **SHA-2** or **SHA-3**.
- ③ **SHA-2** (Secure Hash Algorithm 2)
 - Designed by NIST & NSA in 2001 to replace SHA-1.
 - Many variants (e.g., **SHA-256**).
 - SHA-256 produces a 256-bit hash (64 hex digits).

A hash is **not** considered to be cryptographically secure if two files have the same hash value (i.e., hash collision).

Security professionals use hash values to gain insight into malware, malicious or suspicious files, and to uniquely identify and reference malicious artifacts.

Why Hashes are Useful?

- ✓ Identify known malicious files quickly
- ✓ Lookup reputation using online tools
- ✓ Share **IOCs** (Indicators of Compromise) with the security community
- ✓ Help in threat hunting & incident response



You've seen in ransomware reports that researchers provide hashes of malicious/suspicious files at the end of the report.
Example: The DFIR Report

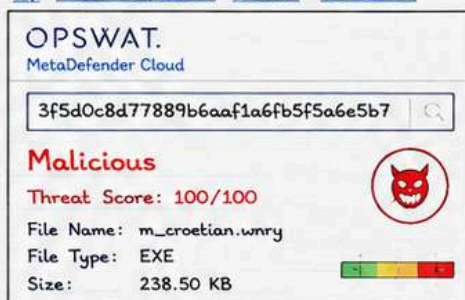
Online Tools for Hash Lookups

1) VirusTotal



Filename: m_croetian.wnry

2) MetaDefender Cloud - OPSWAT



Important Note!

As an attacker, modifying a file by even a single bit is trivial, which would produce a **different** hash value.

↓
With so many variations of malware/ransomware, threat hunting using file hashes as IOC can become difficult.

Example: Changing the Hash Value of a File

File Hash (Before Modification)

```
PS C:\Users\THM\Downloads> Get-FileHash .\OpenVPN_2.5.1_I601_amd64.msi -Algorithm MD5
```

Algorithm	Hash	Path
MD5	D1A008E3A606F24590A02B853E955CF7	C:\Users\THM\Downloads\ OpenVPN_2.5.1_I601_amd64.msi

Original File



→ (Modify)

File Modified



File Hash (After Modification)

```
PS C:\Users\THM\Downloads> echo "AppendTheHash" >> .\OpenVPN_2.5.1_I601_amd64.msi
```

```
PS C:\Users\THM\Downloads> Get-FileHash .\OpenVPN_2.5.1_I601_amd64.msi -Algorithm MD5
```

Algorithm	Hash	Path
MD5	9D52B46F5DE41B73418F8E0DACEC5E9F	C:\Users\THM\Downloads\ OpenVPN_2.5.1_I601_amd64.msi

★ Even a tiny change (like appending a string) = **Completely different** hash value!

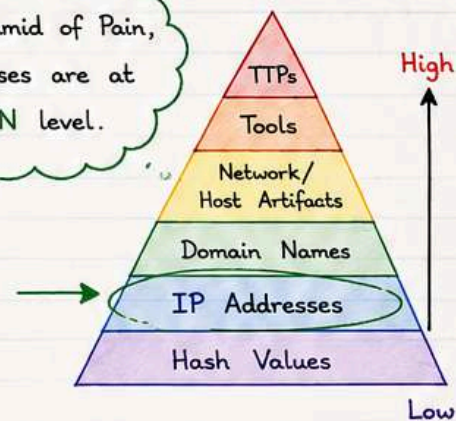
Task 3 IP Address (Easy)

An IP address is used to identify any device connected to a network. These devices range from desktops, servers, to even **CCTV cameras**!

We rely on IP addresses to send and receive information over the network.

(We won't get into the structure and functionality of IP addresses here.)

In the Pyramid of Pain, IP Addresses are at the **GREEN** level.



★ Why are IP Addresses useful from a defense standpoint?

Knowing the IP addresses an adversary uses can be valuable. A common defense tactic is to **block**, **drop**, or **deny** inbound requests from IP addresses on your **perimeter** or **external firewall**.



However, this tactic is often not bulletproof.

It's **trivial** for an experienced adversary to recover by using a **new public IP address**.

Malicious IP Connections (any.run)

IP Address	Country	ASN	Malicious	Requests
185.183.106.195	Germany	AS50974	True	45
5.45.9.23	Netherlands	AS40575	True	32
103.27.74.12	Singapore	AS133481	True	28
94.103.82.10	Russia	AS60193	True	26
45.144.227.65	France	AS16276	True	18

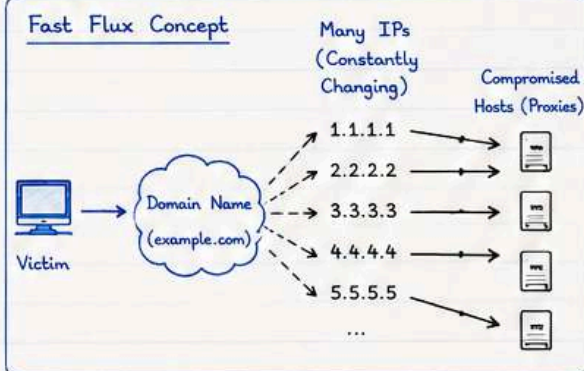
NOTE! Do not attempt to interact with the IP addresses shown above.

One of the ways an adversary can make it challenging to successfully carry out IP blocking is by using **Fast Flux**.

What is Fast Flux?

Fast Flux is a **DNS** technique used by **botnets** to hide **phishing**, web proxying, malware delivery, and malware communication activities behind compromised hosts acting as **proxies**.

The purpose of using Fast Flux is to make the communication between malware and its **command and control server (C&C)** **challenging** to be discovered by security professionals.



★ The primary concept is having **multiple IP addresses** associated with a domain name, which is **constantly changing**.

any.run Report (Sample Analysis)

This report shows malicious IP connections made by the analyzed sample.

Malicious IP Connections

IP Address	Domain	Country	Malicious	Count
185.183.106.195	xmrpool[.]minergate[.]com	Germany	True	23
5.45.9.23	xmrpool[.]com	Netherlands	True	17
103.27.74.12	pool.minexmr[.]com	Singapore	True	15
94.103.82.10	xmr[.]secure-mining[.]net	Russia	True	12
45.144.227.65	xmr-us[.]cf	France	True	11

Summary

- The sample contacted multiple malicious IP addresses.
- These IPs resolve to mining-related domains (likely cryptocurrency mining).
- Using **IP blocking alone will not be effective** if Fast Flux is used.

Key Takeaways



- ✓ IP addresses are easy to obtain and change.
- ✓ Blocking a malicious IP can stop traffic temporarily.
- ✓ Adversaries can use new IPs or Fast Flux to evade detection and blocking.
- ✓ Combine IP intelligence with **other indicators** (domains, hashes, behavior, **TTPs**) for better detection.



Tip: IP addresses are **low** on the Pyramid of Pain because they are **cheap**, **abundant**, and **constantly changeable** by attackers.

Task 4

Domain Names (Simple)

Let's step up the Pyramid of Pain and move on to **Domain Names**. You can see the transition of colors - from green to teal.

★ Domain Names can be thought as simply mapping an IP address to a string of text.

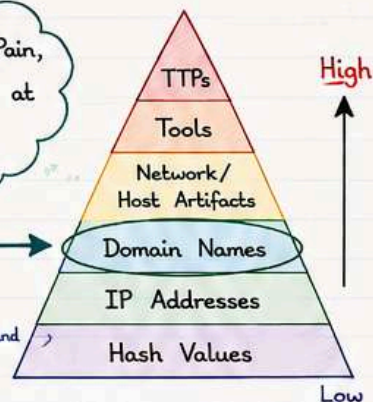
- A domain name can contain a domain and a top-level domain (e.g. evilcorp.com)
- or a sub-domain followed by a domain and top-level domain (e.g. tryhackme.evilcorp.com)

But we will not go into the details of how the Domain Name System (DNS) works. You can learn more about DNS in the "DNS in Detail" Room.

★ Why are Domain Names harder for attackers to change than IPs?

Attackers would most likely need to purchase the domain, register it and modify DNS records. Unfortunately for defenders, many DNS providers have loose standards and provide APIs to make it even easier for the attacker to change domains.

In the Pyramid of Pain, Domain Names are at the **TEAL** level.



Malicious Sodinokibi C2 (Command and Control Infrastructure) domains:

Domain	IP Address	Registrar	Created On
bestbuy-login.com	185.220.101.1	NameCheap, Inc.	2021-06-10
secure-verifyaccount.net	185.220.101.2	NameCheap, Inc.	2021-06-12
account-support.org	185.220.101.3	NameCheap, Inc.	2021-06-13
microsoftsupport.com	185.220.101.4	NameCheap, Inc.	2021-06-14
webcr-update.com	185.220.101.5	NameCheap, Inc.	2021-06-15

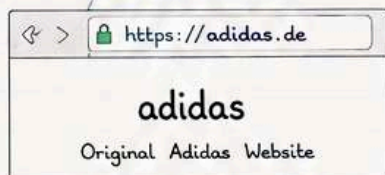
Can you spot anything **malicious** in the above screenshot?

This is an example of a Punycode attack used by attackers to redirect users to a malicious domain that seems legitimate at first glance.

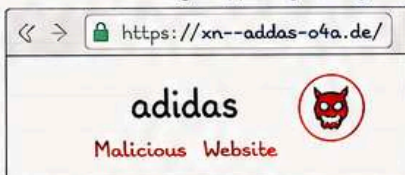
What is Punycode?

As per Jamf, "Punycode is a way of converting words that cannot be written in ASCII, into a Unicode ASCII encoding."

What the user sees



What is actually happening (Punycode)



- ✓ Modern browsers (IE, Chrome, Edge, Safari) are now good at translating the obfuscated characters into the full Punycode domain name.

Attackers hide malicious domains under URL shorteners.

A **URL Shortener** creates a short unique URL that redirects to the specified website.

Common URL Shortening Services:

- bit.ly
- goo.gl
- ow.ly
- s.id
- smarturl.it
- tiny.pl
- tinyurl.com
- x.co

You can view the actual website the shortened link is redirecting you to by appending "+" to it.

Type the shortened URL in the address bar and add "+" at the end to see the redirect URL.

NOTE: The examples below are non-existent.

Short Link	Shortened URL	Add "+" to view
↓	http://bit.ly/abc123 +	→ https://malicious-site.com/login
↻	http://goo.gl/xyz789 +	→ https://bad-domain.net/update
↻	http://tinyurl.com/qwerty +	→ https://evil.example.org/payload
↻	http://ow.ly/!2345 +	→ https://phishing.example.com
↻	http://s.id/abcd +	→ https://dangerous-site.ru/

Any.run provides several tabs under the "networking" section:

1) HTTP Requests



Shows the recorded HTTP requests since the detonation of the sample. Useful to see what resources are being retrieved from a webserver, such as a dropper or a callback.

Method	URL	Status	Size
GET	http://malicious.com/gate.php	200	2.1 KB
GET	http://malicious.com/payload.exe	200	512 KB
POST	http://malicious.com/log.php	200	132 B
GET	http://malicious.com/config.json	200	1.2 KB
...			

2) Connections



Shows any communications made since the detonation of the sample. Useful to see if a process communicates with another host (e.g. C2 traffic, FTP, uploading/downloading files).

Process	Remote IP	Port	Proto
malware.exe	185.220.101.1	443	TCP
malware.exe	185.220.101.2	80	TCP
svchost.exe	8.8.8.8	53	UDP
malware.exe	185.220.101.3	21	TCP

Viewing Connections in Any.run

Any.run is a sandboxing service that executes the sample. We can review any connections such as HTTP requests, DNS requests or processes communicating with an IP address. To do so, look at the "networking" tab located just below the machine snapshot.



Please note: You should be extremely cautious about visiting any of the IP addresses or HTTP requests in a report. These are behaviours from the malware sample - so they're probably doing something dangerous!

3) DNS Requests



Shows the DNS requests made since the detonation of the sample. Malware often makes DNS requests to check for internet connectivity.

Timestamp	Domain	Type	Result
12:33:21	api.malicious.com	A	185.220.101.1
12:33:22	update.malicious.com	A	185.220.101.2
12:33:23	checkip.dyndns.org	A	208.67.222.222
12:33:24	cdn.malicious.com	A	185.220.101.3
...			

Task 5

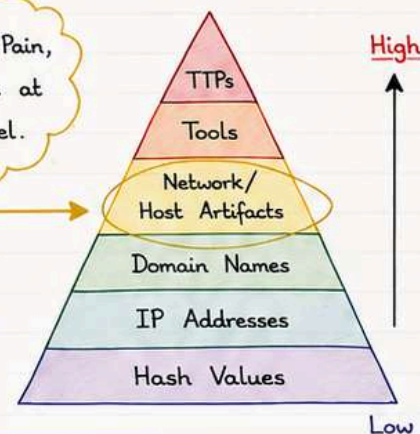
Host Artifacts (Annoying)

Let's take another step up to the **YELLOW** zone.

On this level, the attacker will feel a little more **annoyed** and **frustrated** if you can detect the attack.

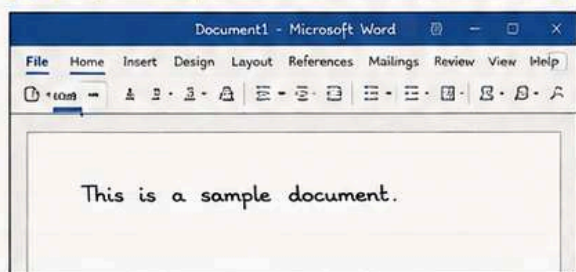
The attacker would need to circle back at this detection level and change his attack tools and methodologies. This is very **time-consuming** for the attacker, and probably, he will need to spend **more resources** on his adversary tools.

In the Pyramid of Pain, Host Artifacts are at the **YELLOW** level.



★ **Host artifacts** are the traces or observables that attackers leave on the system, such as registry values, suspicious process execution, attack patterns or IOCs (Indicators of Compromise), files dropped by malicious applications, or anything exclusive to the current threat.

1) Suspicious process execution from Word:



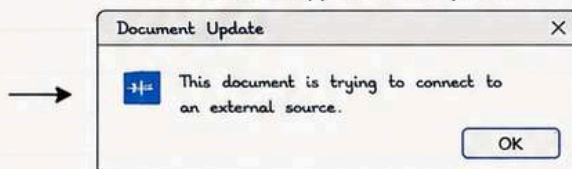
Process	PID	Command Line
WINWORD.EXE	4520	"C:\Program Files\Microsoft Office\WINWORD.EXE"
cmd.exe	6352	cmd.exe /c powershell.exe -nop -w hidden -c "I..."
powershell.exe	6884	powershell.exe -nop -w hidden -c Invoke-WebRequest ...
conhost.exe	7020	C:\Windows\system32\conhost.exe 0x4

Word (WINWORD.EXE) spawning cmd.exe and then PowerShell is **highly suspicious!**

2) Suspicious events followed by opening a malicious application:

Time	Event ID	Event Description
10:15:22	4688	A new process has been created. Process Name: WINWORD.EXE
10:15:28	4663	An attempt was made to access an object. Object: C:\Users\User\Public\invoice.docm
10:15:35	4688	A new process has been created. Process Name: regsvr32.exe
10:15:37	4688	A new process has been created. Process Name: rundll32.exe
10:15:45	4657	A registry value was modified. Key: HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Malicious Application Opened



A chain of **suspicious events** leading to the execution of a **malicious application**.

3) The files modified/dropped by the malicious actor:

Name	Path	Size	Type	Modified Time
update.exe	C:\Users\User\AppData\Roaming\	528 KB	Application	10:16 AM
payload.dll	C:\Users\User\AppData\Roaming\	144 KB	Application extension	10:16 AM
invoice.docm	C:\Users\User\Downloads\	98 KB	Microsoft Word Macro-Enabled	10:15 AM
system.lnk	C:\Users\User\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\	1 KB	Shortcut	10:16 AM
log.txt	C:\Users\User\AppData\Local\Temp\	2 KB	Text Document	10:17 AM



Malicious files dropped or modified on the host are **strong indicators** of compromise.

★ Host artifacts are harder for attackers to change because they are tied to specific **tools**, **techniques** and **behaviours**.

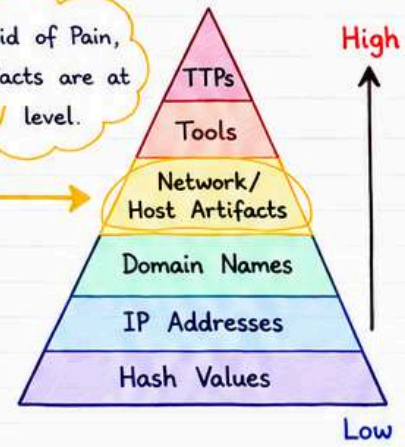
Task 6

Network Artifacts (Annoying)

Network Artifacts also belong to the **YELLOW** zone in the Pyramid of Pain. This means if you can detect and respond to the threat, the attacker would need more time to go back and change his tactics or modify the tools, which gives you more time to respond and detect upcoming threats or remediate the existing ones.

★ A network artifact can be a **user-agent string**, **C2 information**, or **URI patterns** followed by the **HTTP POST requests**.

In the Pyramid of Pain, Network Artifacts are at the **YELLOW** level.



1) What are Network Artifacts?

- User-Agent String**
A string used by the client to identify itself to the server.
- C2 Information**
Domain names, IP addresses or endpoints used for command & control.
- URI Patterns**
Specific paths or patterns in the URL that indicate malicious activity.

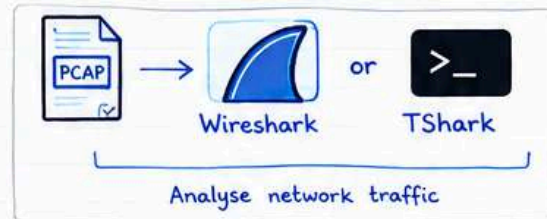
According to **RFC2616**:

"The User-Agent is the request-header field that contains the information about the user agent originating the request."



2) Detecting Network Artifacts

- PCAPs → Use Wireshark or TShark to analyse network packet dumps.
- IDS Alerts → Use tools like Snort to check for suspicious traffic.
- Look for suspicious **HTTP POST** requests.



3) Example: Suspicious HTTP POST Requests

Time	Source IP	Destination IP	Method	URI	User-Agent
10:15:23	10.10.14.6	192.168.1.10	POST	/gate.php	Mozilla/5.0
10:16:05	10.10.14.6	185.199.110.23	POST	/upload	Python-urllib/3.7
10:17:12	10.10.14.6	45.33.32.156	POST	/index.php	Wget/1.19.4
10:18:30	10.10.14.6	172.67.181.64	POST	/api/v1/data	curl/7.68.0

At first glance, it's hard to attribute these requests to a specific malware.

So, dig deeper and look for network indicators like the **User-Agent**!

4) TShark Command

```
tshark --Y http.request -T fields \
-e http.host -e http.user_agent \
-r analysis_file.pcap
```

This command extracts the HTTP host and User-Agent from the PCAP file.

5) Emotet User-Agent Strings

Common Emotet User-Agent Strings

Mozilla/5.0 (Windows NT 6.1; Trident/7.0)

Mozilla/5.0 (Windows NT 10.0; Win64; x64)

Mozilla/5.0 (Windows NT 6.1; WOW64)

Mozilla/5.0 (Windows NT 10.0; WOW64)

Mozilla/5.0 (Windows NT 6.2; Trident/7.0)

Why does this matter?

- If you can detect these User-Agent strings, you can **block** them.
- This creates more obstacles for the attacker, making their attempt to compromise the network **more annoying** and time-consuming.

Key Takeaways

- ✓ Network artifacts include User-Agent strings, C2 info and URI patterns.
- ✓ Analyse PCAPs with Wireshark/TShark and check IDS alerts from tools like Snort.
- ✓ Use TShark to extract HTTP host and User-Agent.
- ✓ Emotet uses specific User-Agent strings – detect and block them!



Network artifacts are annoying for attackers because they are easier to detect and block, forcing them to change tactics and waste time!

Task 7

Tools (Challenging)

★ Congratulations!

We have made it to the **CHALLENGING** part for the adversaries!

At this stage, we have levelled up our detection capabilities against the artifacts.

The attacker would most likely give up trying to break into your network or go back and try to create a **new tool** that serves the same purpose.

It will be a game over for the attackers as they would need to **invest some money** into building a new tool (if they are capable of doing so), find the tool that has the same potential, or even gets some **training** to learn how to be proficient in a certain tool.

1) A Trojan dropped the suspicious "Stealer.exe" in the Temp folder:

This PC > Local Disk (C:) > Users > THM > AppData > Local > Temp			
Name	Date modified	Type	Size
...			
chrome_installer.log	5/14/2025 10:01 AM	Text Document	1 KB
tmpA7B3.tmp	5/14/2025 10:01 AM	TMP File	12 KB
Stealer.exe	5/14/2025 10:01 AM	Application	348 KB
tmpB12C.tmp	5/14/2025 10:02 AM	TMP File	8 KB
...			

→ A malicious program drops a suspicious binary (**Stealer.exe**) into the Temp directory.

Defend at this level using strong weapons!



Antivirus **signatures**, **detection rules**, and **YARA rules** are great weapons at this stage.



These help you detect and stop malicious tools and binaries used by attackers.

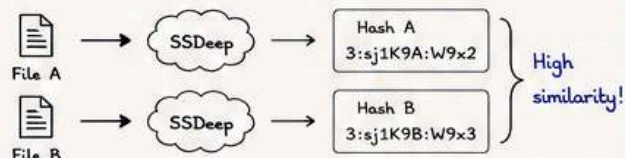


Combine multiple defenses for the best coverage and visibility.

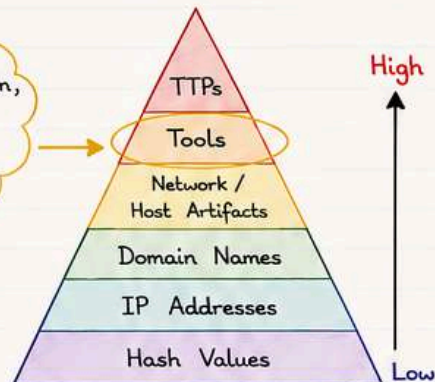
Fuzzy hashing is also a strong weapon against attacker's tools. It helps you perform **similarity analysis** - match two files with minor differences based on the fuzzy hash values.

Example of Fuzzy Hashing: SSDeep

SSDeep (Context Triggered Piecewise Hashing) is one of the examples of fuzzy hashing. It generates hash values that remain similar even if files have small changes.



In the Pyramid of Pain, **Tools** are at the **YELLOW** level.



★ Attackers would use the utilities to create malicious macro documents (maldocs) for spearphishing attempts, a backdoor that can be used to establish **C2** (Command and Control Infrastructure), any custom **.EXE**, and **.DLL** files, payloads, or password crackers.

2) The execution of the suspicious binary:

```
PS C:\Users\THM\AppData\Local\Temp> .\Stealer.exe
```

```
Stealer.exe started...
Collecting system information...
Grabbing passwords...
Sending data to C2 server 185.220.101.5:443 ...
Done.
Press any key to exit...
PS C:\Users\THM\AppData\Local\Temp> █
```

→ The suspicious binary is executed and may connect to a **C2** server to exfiltrate data.

Great Resources

Malware Bazaar

- Provides access to malware samples
 - Malicious feeds
 - YARA results
- Great for threat hunting and incident response.

MalShare

- Malware samples
 - Community-driven
 - IOC & YARA sharing
- Useful for research and validation.

SOC PRIME

- Threat Detection Marketplace
 - Detection rules for many threats
 - Includes latest CVE's exploited in the wild
- Community-shared detection rules for faster detection.

SSDeep example from VirusTotal

File 1

SHA256: 3f2b8f5e6c5b8e1b7d4c7f2e9a8d0b1c3e4f5...
 ssdeep:
 3072:4xJ8k9Yb7mL3qZ2y1R6/3b7c8d:4xJ8k9Yb7mL3qZ2y1R6/3b7c8e
 File name: sample1.exe
 Detection ratio: 32 / 72
 Analysis date: 2025-05-14 10:31:22 UTC

0 / 72

File 2 (Slightly modified)

SHA256: 6a8d9f1c2b3e4f5a7d8c9b0a1e2f3d4c5b6a7...
 ssdeep:
 3072:4xJ8k9Yb7mL3qZ2y1R6/3b7c8d:4xJ8k9Yb7mL3qZ2y1R6/3b7c8f
 File name: sample1_modified.exe
 Detection ratio: 31 / 72
 Analysis date: 2025-05-14 10:33:18 UTC

0 / 72

SSDeep similarity: 99.3% match



Key Takeaway:

Tools are **CHALLENGING** to detect because they are unique and often custom-built. Detecting them requires **advanced techniques**, **threat intelligence**, and strong **detection engineering**.

Task 8

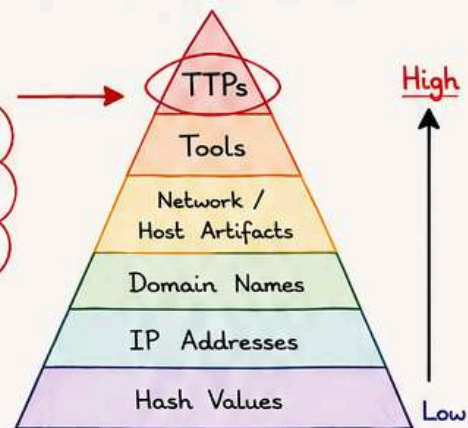
TTPs (Tough)

★ We made it to the APEX!

But it is not over yet.

TTPs stands for **T**actics, **T**echniques & **P**rocedures. This includes the whole **MITRE ATT&CK Matrix**, which means all the steps taken by an adversary to achieve his goal, starting from phishing attempts to persistence and data exfiltration.

In the Pyramid of Pain, TTPs are at the **TOP** (apex) - the most painful level for attackers!



If you can detect and respond to the TTPs quickly, you leave the adversaries almost no chance to fight back.

TTPs cover the entire kill chain / attack lifecycle - from initial access to impact.

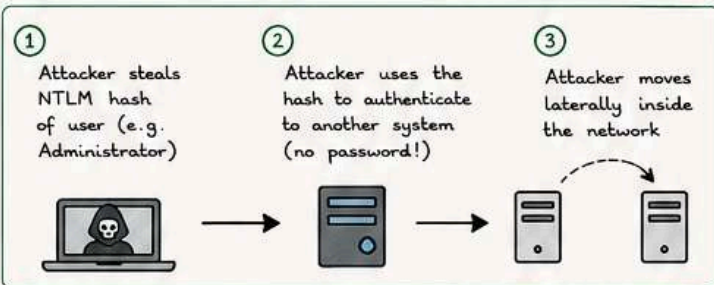
The MITRE ATT&CK Matrix (example)

The matrix organizes adversary behaviours by Tactics (columns) and Techniques (cards).

Initial Access	Execution	Persistence	Privilege Escalation	Credential Access	Lateral Movement	Collection	Exfiltration	Impact
- Phishing - Spearphishing Attachment - Valid Accounts	- Command and Scripting Interpreter - PowerShell - User Execution	- Registry Run Keys - Scheduled Task - Service Modification	- Exploit for Privilege Escalation - Abuse UAC	- Dump LSASS - Brute Force - Credential Stealing	Pass-the-Hash - WMI - Remote Services	- Data from Local System - Screen Capture - Keylogging	- Exfiltration Over C2 Channel - Exfiltration to Cloud	- Data Destruction - Ransomware - Data Encrypted

Example: Detecting a Pass-the-Hash (PtH) attack

Pass-the-Hash allows an attacker to authenticate using a user's NTLM hash instead of the password.



By monitoring these events, you can spot unusual authentications and identify compromised hosts quickly.

Windows Event Log Indicators

Event ID	Source	What it indicates
4624	Microsoft-Windows-Security-Auditing	Successful logon - look for logon type 3 (network)
4634	Microsoft-Windows-Security-Auditing	Logoff event
4672	Microsoft-Windows-Security-Auditing	Special privileges assigned to new logon (often seen after PtH)
4648	Microsoft-Windows-Security-Auditing	Explicit credentials used (another sign of credential abuse)

Response: Stop the attack early!

- ✓ Detect suspicious TTPs (e.g., PtH attempt)
- ✓ Investigate and confirm the compromise
- ✓ Contain & remove the threat (isolating host, resetting credentials, patching, etc.)
- ✓ Hunt for additional activity & monitor for recurrence

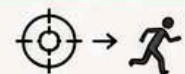


What can the attacker do now?

① Go back, do more research & training, reconfigure their custom tools, and try again.



② Give up and find another target.



Option 2 is definitely less time and resource-consuming for the attacker!



★ Key Takeaway:

TTPs are the hardest for attackers to change because they require changing the entire strategy and behavior chain, not just a tool or an IP address.

Master the detection of TTPs, and you stay one step ahead!

